

Cisco Secure Workload - MAS TRM Compliance Report

Cisco Secure Workload - MAS TRM Compliance Report

Customer-Facing Compliance Report

Framework: Monetary Authority of Singapore (MAS) Technology Risk Management Guidelines

Primary audience: Singapore-licensed financial institutions (banks, finance companies, insurers, capital markets services licensees, payment services licensees) using MAS TRM as the technology risk baseline.

CSW positioning: Critical-system segmentation, technology-asset evidence, outsourcing visibility, vulnerability context, monitoring, and incident scoping.

Framework Version Note

References the MAS TRM Guidelines published January 2021 (current published version at the time of writing). Validate against the latest MAS publication before use in a supervisory or audit context.

CSW UI Navigation Note

Cisco does not yet publish framework-specific CSW UI navigation for this standard; framework-specific navigation is on the product roadmap. This report references CSW *capabilities* and the *evidence artifacts* they produce. The technical runbook (CSW-MAS-TRM-Technical-Runbook.md) in this folder contains the deeper engineering detail.

How to read the Coverage column

Every report in this set uses the same three coverage words. Coverage describes **what evidence CSW produces** for a topic — it never means the control is passed.

Direct — Secure Workload produces the primary evidence artifact for that topic (segmentation, policy, flow/process telemetry, inventory, vulnerability + reachability, forensic reconstruction). Direct is still evidence, not an attestation.

Supporting — Secure Workload contributes an input that feeds or complements another control, tool, or process (e.g. detection input only, reconciled against an external register, one log source among several).

Evidence Required — Secure Workload has no record for this topic. The customer supplies the contract, the analysis, or the HR / physical-security evidence from another control.

The Coverage ratings in the topic map below are machine-derived from each row's wording and are flagged for SE review before customer use.

Executive Summary

Cisco Secure Workload (CSW) supports a defined subset of this framework. The strongest customer story is not that CSW “certifies” compliance; it is that CSW turns workload communication and inventory into evidence that the customer, the customer’s compliance team, and the customer’s assessor can review. This report describes which framework topics CSW supports, which it does not, what evidence artifacts CSW produces, and how often the customer should collect them. CSW does **not** replace the customer’s governance, policy, or assessor judgement, and this report is **not** a control attestation.

Suggested CSW Scope Pattern

MAS-TRM

- └ Critical-Systems (Digital-Banking, Payments, Trading, Core-Platforms)
- └ Customer-Data (Data-Stores, Analytics)
- └ Security-Services (Identity-Adjacent, Monitoring, Patch-Management)
- └ Outsourced-Third-Parties

This scope pattern should be validated with the customer’s architecture, application owners, compliance team, and assessor before it is used for formal evidence.

In Scope for CSW Evidence

- Technology Risk Management Framework (asset inventory, classification)
- Access Control (workload-to-workload allowlist)
- Data and Infrastructure Security (segmentation, plaintext-flow detection)
- Cyber Security Operations (telemetry, alerts, forensic search)
- Cyber Security Assessment (CVE + reachability)
- Management of IT Services / Outsourcing (third-party egress visibility)
- IT Audit (evidence pack inputs)

Out of Scope (Must Be Evidenced by Other Controls / Tools / Processes)

- Governance and board oversight
- Cryptography module assurance
- Identity / privileged-access lifecycle
- Business continuity / disaster recovery testing
- Outsourcing due diligence and supplier assurance contracts
- MAS reporting / notification decisions

Framework Topic → CSW Capability Map

Framework topic	Coverage	CSW capability	Evidence artifact
Technology asset inventory	Direct	Workload inventory; scope + label export	Inventory export reconciled to institution CMDB
Information security risk assessment	Direct	Vulnerability + reachability report	Reachability-weighted exposure summary scoped to MAS-TRM
Access control (network access layer)	Direct	Policy workspace + enforcement log	Workspace snapshot and violation/exception register
Data security	Direct	Plaintext-flow detection from observed flows	List of unencrypted flows on customer-data paths
Vulnerability management	Direct	Reachability-weighted CVE evidence	Prioritised remediation list with compensating-control register
Security monitoring	Direct	Continuous flow + process telemetry	Alert and anomaly log scoped to Critical-Systems
Cyber security operations / incident	Direct	Forensic flow + process search	Investigation pack covering affected workloads and time window
Management of IT services / outsourcing	Supporting	Outbound flow summary to third-party endpoints	Vendor-edge flow report reconciled against outsourcing register
IT audit	Direct	Periodic evidence pack	Quarterly inventory, policy, vulnerability, incident-sample bundle

Evidence Collection Approach

The table below describes per-topic evidence collection - what to collect, the CSW source area, and a suggested cadence. The cadence should be tuned to the customer's audit cycle, regulatory cadence, and risk appetite.

Topic	What to collect	CSW source	Suggested cadence
Critical-system inventory	Inventory export with scope, labels, and lifecycle	Workload inventory + scope membership export	Monthly
Approved vs. observed flows	ADM output vs. enforced policy	ADM workspace export	Quarterly
Policy enforcement evidence	Workspace snapshot + violation log	Policy workspace export and policy analysis output	Quarterly + after each change
Vulnerability + reachability	CVE list weighted by reach into Critical-Systems	Vulnerability report scoped to MAS-TRM	Monthly
Third-party egress reconciliation	Outbound flow to vendor endpoints	Flow search filtered to outsourced endpoints	Monthly
Incident sample	Workload-level timeline for one representative incident	Flow + process search	Per incident; one representative sample per audit cycle

POV / Workshop Approach

1. Confirm the framework version and assessment cycle with the customer's compliance team.
2. Select one business service, regulated boundary, or critical workload group to start with; do not attempt to instrument the entire estate in the POV.
3. Validate workload coverage and install sensors or configure supported connectors. Document the cannot-instrument register; this is itself evidence.
4. Apply labels for application, environment, owner, data class, criticality, compliance scope, and any framework-specific tags (e.g. `tenant`, `prototype`, `isa_level`, `npi`, `cui`, `ephi`).
5. Observe flows over a representative business window. Minimum two weeks; longer if the customer has month-end, quarterly, or seasonal cycles relevant to the scope.
6. Use ADM to generate a candidate policy. Review with the application owner. Run in Simulation mode for at least two weeks before any enforcement.
7. Package inventory, scope, flows, policy, exceptions, and known gaps as the evidence output. Cross-reference this report's evidence collection table with the customer's existing audit work-papers.

Boundaries and Complementary Controls

CSW does not replace MAS-level governance, board / senior-management accountability, the technology risk management framework, BCP/DR, IAM/PAM, cryptography programme decisions, outsourcing due diligence, or regulatory notification decisions.

Assessor / Auditor Caveat

CSW provides technical evidence inputs. The customer's qualified assessor, auditor, certifying body, or regulator determines compliance status. Validate all framework-topic mappings, control IDs, paragraph references, and section numbers in this report against the current official framework text. If the customer is being assessed against a version other than the one referenced in the framework version note above, revalidate before use.

Disclaimer

This report is for informational and planning purposes. It is not legal, regulatory, audit, or certification advice. Validate all mappings against the current official framework text, the customer's environment, and qualified compliance, legal, and audit professionals.